Security Requirements & Planning Document

1. Authentication & Session Security

1.1 Login & Registration

- **SSO via OAuth2** with secure token verification.
- **JWT** for stateless API authentication combined with **server-side session store** for revocation and MFA state.
- **Email OTP** for MFA after primary credentials are validated.
- Rate limit login attempts to mitigate brute force.

1.2 Password Reset

- One-time secure tokens with expiration and replay protection.
- Risk alerts and audit logs for resets.

1.3 Session Management

- Short-lived access tokens & refresh token rotation.
- Inactivity timeout, session revocation, device listing.

1.4 RBAC

- Fine-grained roles: patient, doctor, admin.
- Enforce permissions on every endpoint and UI action.

2. API & Application Security Controls

3.1 Input Validation & API Hardening

- Strict schema validation (body/query headers).
- Parameterized queries / stored procedures to prevent SQL injection.
- Protection against abundant web threats (parameter pollution, malformed headers).

3.2 Rate Limiting

- Global and per-endpoint rate limits preventing abuse.
- Log over-limit events for SIEM analysis.

3.3 Secure Error Handling

- No internal system details in client-facing errors (Custom 404 webpage)

3. Data Protection & Encryption

3.1 Encryption

- **TLS 1.3+** for all API traffic and inter-service communication.
- AES-256 encryption at rest for all PHI and sensitive data.

4. Supabase Row Level Security

To ensure strict data isolation at the database layer, **Supabase Row Level Security (RLS)** must be applied:

4.1 RLS Policy Requirement

- **RLS must be enabled on all tables containing sensitive or access-controlled data.**
- Each table must have **explicit RLS policies** enforcing per-user/role access logic, preventing unintended data exposure.

4.2 RLS Policies

- Patient tables: users can only access their own data.
- Doctor tables: doctors can access only assigned patients' data.
- Admin tables: policies differentiate admin roles and scopes.

5. Infrastructure Security

5.1 NGINX Reverse Proxy

- Enforce TLS termination, security headers (CSP, HSTS, X-Frame-Options).
- Validate host headers and drop unexpected values.
- Perform rate limiting and filtering before reaching the application.

5.2 Custom Application-Level WAF

- Inspect HTTP/HTTPS application traffic for SQLi, XSS, CSRF, and business logic violations.
- Support adjustable rule sets.
- Integrate with SIEM for real-time alerts on blocked patterns.

6. Dashboards & Feature Protection

6.1 Patient Dashboard

- Secure views with RBAC and RLS.
- File uploads (reports/labs) encrypted at rest.
- End-to-end encrypted chat with secure message storage.

6.2 Doctor Dashboard

- Doctors can view only assigned patients via strict RBAC and RLS.
- Logging of sensitive view/edit operations.
- Rate limiting and input sanitization on all input parameters.

6.3 Admin Dashboard

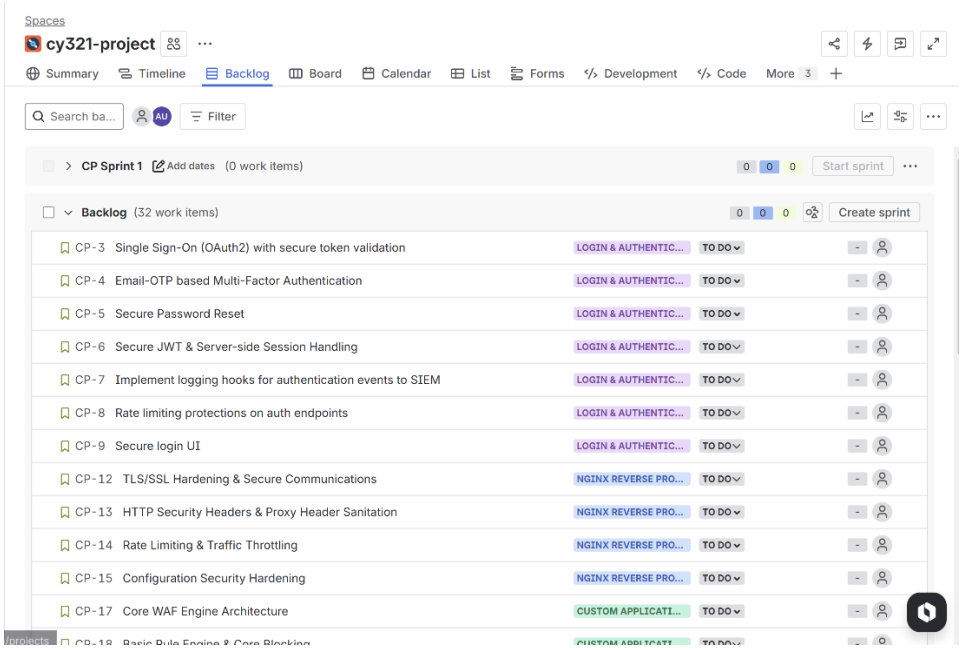
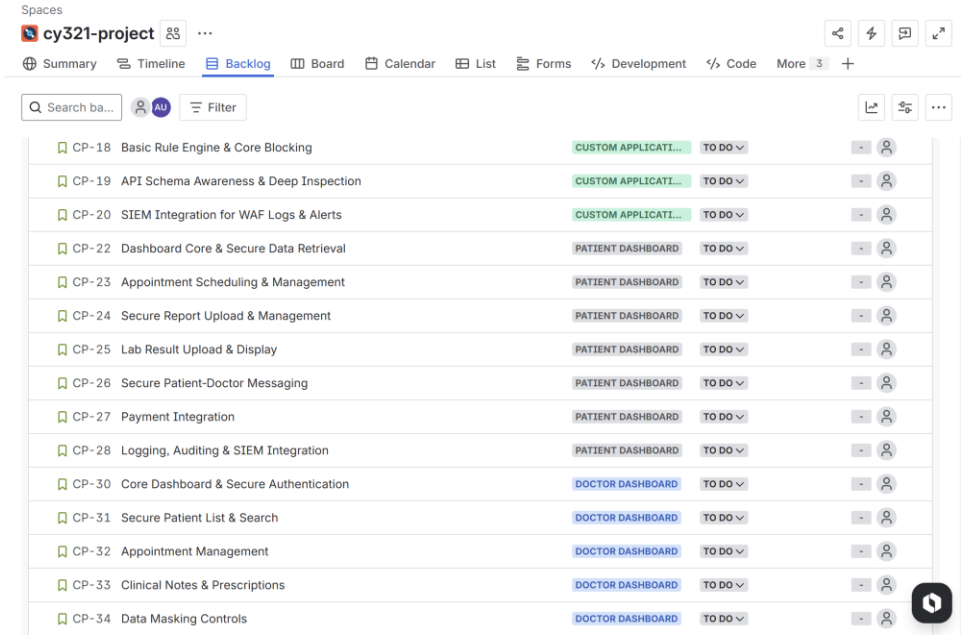
- Admin actions on user accounts, payments, and assignments logged.
- MFA enforced for admin logins; sensitive settings require stronger approvals.

7. Logging & Monitoring

7.1 Structured Logging

- Log all access, modifications, authentication events, failures with metadata.

7.2 SIEM Integration

- Forward logs to Wazuh SIEM for correlation, threat detection, and compliance dashboards.
- Alerts for suspicious patterns: multiple failed logins.

Jira Requirements Management